Semana 06 — Verificar el cierre del alcance desde fuera

Grupo 3 · rol Rojo · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	06 de 10
Fase	3 — Defensa y hardening
Grupo	3
Rol	Rojo
Entrega	GitHub, carpeta semana_06/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash.

- Confirmar el objetivo autorizado y preparar el entorno antes de la primera captura.
- Ejecutar la técnica de la semana en el orden de los pasos y guardar cada salida cruda con su hash.
- Redactar la reproducción: comando, salida esperada y salida obtenida, sin retocar la evidencia.

2 Qué aporta este rol al entregable

Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.

3 Ejemplo paso a paso

El rol Rojo repite el escaneo despues del hardening y comprueba que lo que debia cerrarse se cerro. Tambien busca el camino que la politica dejo abierto sin querer.

3.1 Escanear el alcance antes y despues

El mismo comando, la misma tasa y el mismo objetivo. La comparacion es puerto por puerto, no una impresion general.

```
mkdir -p semana_06/evidencia
nmap -sT -p 22,2222,8081,3000 --max-rate 20 127.0.0.1 \
  -oN semana_06/evidencia/antes.txt
nmap -sT -p 22,2222,8081,3000 --max-rate 20 127.0.0.1 \
  -oN semana_06/evidencia/despues.txt
diff -u semana_06/evidencia/antes.txt semana_06/evidencia/despues.txt \
  | tee semana_06/evidencia/diff.txt
```

3.2 Probar si el puerto cerrado responde de otra forma

Un puerto filtrado no es lo mismo que uno cerrado: se distingue con la salida de nmap y con una conexion directa cronometrada.

```
python3 - <<'PY' | tee semana_06/evidencia/cierre.txt
import socket, time
for puerto in (22, 2222):
    s = socket.socket(); s.settimeout(1.0)
    t = time.perf_counter()
    try:
        s.connect(('127.0.0.1', puerto)); estado = 'abierto'
    except socket.timeout:
        estado = 'filtrado'
    except ConnectionRefusedError:
        estado = 'cerrado'
    finally:
        s.close()
    print(puerto, estado, round(time.perf_counter() - t, 3), 's')
PY
```

3.3 Buscar el servicio que quedo expuesto

La politica por defecto deja pasar solo lo autorizado. Se revisa la lista de reglas y se comprueba que no haya un allow mas amplio de lo necesario.

```
sudo ufw status numbered | tee semana_06/evidencia/ufw_reglas.txt
```

3.4 Documentar el intento fallido

Un intento que no funciona tambien es resultado: demuestra que el control esta en el camino y no solo en el documento.

3.5 Puerto, estado y conclusion

Puerto, estado y conclusion

Puerto	Antes	Despues	Intento posterior	Conclusion
22	Abierto	Filtrado	Conexion directa	Control efectivo
2222	Abierto	Abierto	Acceso con clave	Permitido por alcance
8081	Abierto	Abierto	Peticion HTTP	Permitido por alcance
3000	Abierto	Abierto	Peticion HTTP	Permitido por alcance

La conclusion se escribe como control efectivo, control parcial o sin cambio. El "sin cambio" se justifica.

4 Qué guardar en el repositorio

Se entrega el escaneo antes y despues, el diff, la prueba del cierre por puerto y la revision de las reglas de filtrado.

```
semana_06/
|-- informe.md
|-- auditor.sh
|-- evidencia/
|   |-- antes.txt
|   |-- despues.txt
|   |-- diff.txt
|   |-- cierre.txt
|   `-- ufw_reglas.txt
`-- README.md
```

- El escaneo usa el mismo comando antes y despues.
- Se distingue filtrado de cerrado con una prueba cronometrada.
- Las reglas de filtrado se revisan, no solo se activan.
- Cada "sin cambio" esta justificado por el alcance.

5 Cómo se corrige

Criterio	Peso
Doce controles documentados y verificables	2,0
Auditor funcional con veredicto por control	2,0
Política de filtrado correcta y sistema operativo	2,5
Alertas de Suricata clasificadas y regla propuesta	2,5
Antes/después comparables y justificación de excepciones	1,0
Total	**10,0**

- {'Cerrar un puerto que el grupo necesita rompe el laboratorio': 'se comprueba el alcance.'}
- El escaneo se hace solo contra 127.0.0.1.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.